

ENCUESTA INTEGRAL DE CIBERSEGURIDAD DORA

Modelo Detallado con Módulos y Escalas de Madurez

Versión: 1.0

Fecha: Enero 2026

Clasificación: Profesional - Evaluación Institucional

Público Objetivo: Responsables de Seguridad, CISOs, Directores TI, Órganos de Gobernanza

INTRODUCCIÓN Y CONTEXTO

Esta encuesta integral ha sido diseñada como herramienta de evaluación cuantitativa y cualitativa para instituciones financieras reguladas bajo el **Digital Operational Resilience Act (DORA, EU 2022/2554)**. Su propósito es diagnosticar el estado de madurez cibernética actual de su organización, identificar brechas críticas, y proporcionar líneas base para roadmaps de mejora continua.

Principios Rectores de Diseño

La encuesta adopta un **enfoque humorístico-propositivo** manteniendo rigor profesional, reconociendo que:

- La ciberseguridad es asunto serio, pero no debe ser sombría
- Las organizaciones responden mejor a feedback constructivo que a crítica despiadada
- La ironía facilita la retención de mensajes complejos
- El tono amable incrementa tasas de respuesta honesta (vs. defensiva)

Escala de Intensidad: Las preguntas emplean gradaciones de **5 puntos (Likert modificado)** permitiendo matices entre extremos.

MÓDULO 1: GOBERNANZA Y RESPONSABILIDAD INSTITUCIONAL

1.1 Liderazgo y Compromiso de Órganos Directivos

Pregunta 1.1.1 ¿Con qué frecuencia los órganos de gobernanza (Junta Directiva / Comité Riesgos) reciben reportes formales sobre resiliencia operativa digital y cumplimiento DORA?

- (1) Nunca. "¿Eso existe?" es la respuesta típica del board en reuniones.
- (2) Ad-hoc. Solo cuando algo explota. Reactividad pura.
- (3) Semestralmente. Lo suficiente para marcar casilla de cumplimiento.
- (4) Trimestralmente. Reportes estructurados con KPIs integrados.
- (5) Mensualmente + alertas escaladas. Governance continuo, data-driven decision making.

Pregunta 1.1.2 ¿Existe designación formal de responsabilidad cibernética (p.ej., CISO, Chief Digital Resilience Officer, ICT Risk Lead) con reportería directa a nivel C-suite?

- (1) No designado. La ciberseguridad es "responsabilidad de todos" (spoiler: no lo es).
- (2) Rol ad-hoc. Alguien en IT "también" hace ciberseguridad. A tiempo parcial.
- (3) Rol designado (no director). Existe, pero reporta a TI o Compliance, no a ejecutivos.
- (4) CISO designado. Reporta a CRO/CEO; integrado en governance formal.
- (5) CISO + equipo de riesgos dedicado. Full-time, multi-disciplinario, autoridad real.

Pregunta 1.1.3 ¿La estrategia de resiliencia digital está documentada, aprobada por Junta, e integrada en objetivos estratégicos empresariales (no como documento aislado)?

- (1) No existe estrategia documentada. Living in the moment es cool, pero no para ciberseguridad.
- (2) Existe documento técnico. Escrito por IT, no conocido por ejecutivos.
- (3) Estrategia documentada, aprobada por Junta. No integrada en KPIs empresariales.
- (4) Estrategia aprobada, KPIs integrados. Reportes trimestrales a junta; presupuesto garantizado.
- (5) Estrategia integrada (enterprise risk strategy). Alineada con visión empresarial; presupuesto multi-año; evoluciona conforme threat landscape.

Pregunta 1.1.4 ¿La Junta Directiva incluye al menos un miembro con expertise substantivo en ciberseguridad / tecnología?

- (1) No. "Mi sobrinito sabe de ordenadores" no cuenta.
- (2) Poco. Un miembro con bagaje técnico de hace 10+ años.
- (3) Moderado. Uno-dos miembros con expertise reciente / consultores externos.
- (4) Sustancial. Múltiples miembros con expertise ciberseguridad o CISO ext. asesor.
- (5) Substantivo + entrenamiento continuo. Members con expertise; board training anual; CISO es resource permanente.

Pregunta 1.1.5 ¿Se han establecido políticas de responsabilidad personal de órganos directivos en caso de incumplimiento DORA? (Article 5 DORA explícito)

- (1) No. Incumplimiento DORA = "culpa de TI". Punto.
- (2) Vago. Alguien "podría" ser responsable, pero mecanismos no están claros.
- (3) Parcial. Responsabilidad definida para ciertos incumplimientos materiales.
- (4) Definida formalmente. Políticas documentadas; comité audit realiza supervisión.
- (5) Explícita + enforcement. Responsabilidades personales en acuerdos directivos; supervisión audit continua; insurance cyberseguridad cubre gaps.

1.2 Políticas de Seguridad y Marco de Gobernanza

Pregunta 1.2.1 ¿Existe política integral de seguridad TIC documentada, aprobada por Junta, y revisada formalmente al menos anualmente?

- (1) No existe. ¿Quién la necesita cuando tienes intuición?
- (2) Existe, no documentada. "Todos sabemos las reglas" (spoiler: no saben).
- (3) Documentada pero raramente revisada. Del 2015, probablemente.
- (4) Documentada, revisada anualmente, accesible. Versionado; conocida por staff.
- (5) Documentada + revisada + enforcement + training continuo. Living policy; evoluciona con threat landscape; 100% staff comprehension.

Pregunta 1.2.2 ¿Las políticas de seguridad incluyen explícitamente requisitos DORA (gestión de riesgos TIC, gestión incidentes, testing resiliencia, terceros)?

- (1) No menciona DORA. No sé ni qué es. (Problema serio.)
- (2) Mención genérica. "Sí, ciberseguridad" tipo vago.
- (3) Cobertura parcial. Algunos pilares DORA abarcados; otros no.
- (4) Cobertura completa 5 pilares. Documentado; mappings claros.
- (5) Integración total DORA. Política es roadmap DORA; métricas DORA embebidas; escalation protocols DORA normalizados.

Pregunta 1.2.3 ¿Existen políticas documentadas para cumplimiento de requisitos de terceros (proveedores TIC críticos) conforme Artículos 28-30 DORA?

- (1) No existe política de terceros. Compramos servicios; confío en su competencia.
- (2) Policy básica. Existe pero es esquelética / desactualizada.
- (3) Policy documentada. Define due diligence inicial; no monitoreo continuo.
- (4) Policy completa. Evaluación inicial + monitoreo anual + contractual safeguards.
- (5) Policy integral DORA. Evaluación riesgo proporcional, monitoreo continuo, cláusulas audit, SLAs RTO/RPO, salida plans, integrado en enterprise risk.

MÓDULO 2: GESTIÓN DE RIESGOS TIC

2.1 Identificación y Evaluación de Riesgos

Pregunta 2.1.1 ¿Se realiza evaluación formal de riesgos TIC conforme NIST SP 800-30 o metodología equivalente ISO 27005?

- (1) No formal. Reaccionamos cuando algo falla.
- (2) Ad-hoc. Ocasionalmente identificamos riesgos; documentación inconsistente.
- (3) Evaluación anual. Metodología documentada; realizada cada 12 meses.
- (4) Evaluación anual + seguimiento semestral. Revisiones programadas; incidentes actualizados en reporte.
- (5) Continua + automatizada. Risk scoring dinamico; herramientas scanning continuas; alertas escalonadas; governance integrado.

Pregunta 2.1.2 ¿Se mantiene inventario actualizado de activos TIC críticos, sistemas, y datos sensibles (mapeo de criticidad)?

- (1) No existe inventario. ¿Qué sistemas tenemos exactamente? Buena pregunta.
- (2) Inventario básico. Listado incompleto; desactualizado 50% del tiempo.
- (3) Inventario documentado. Actualizado anualmente; cobertura ~80% sistemas.
- (4) Inventario integrado CMDB. Actualizado semestralmente; criticidad clasificada; 95% cobertura.
- (5) Inventario dinámico / automatizado. Real-time discovery; criticidad auto-scored; integrado monitoreo continuo; 100% cobertura.

Pregunta 2.1.3 ¿Se han identificado formalmente funciones críticas e importantes de su organización conforme Artículos 2(16-17) DORA?

- (1) No identificadas. Todas nuestras funciones son críticas (realidad: muchas no lo son).
- (2) Identificación informal. Sabemos "intuitivamente" cuáles son críticas.
- (3) Documentadas parcialmente. 60-70% funciones críticas/importantes mapeadas.
- (4) Documentadas formalmente. Listado exhaustivo; mapeo a sistemas; RTO/RPO definidos.
- (5) Documentadas + validadas + monitoreadas. Framework formalizado; revalidado anualmente; métricas de función crítica integradas en governance.

Pregunta 2.1.4 ¿La evaluación de riesgo considera amenazas específicas a sector financiero (ransomware, DDoS, intrusion, supply chain attacks)?

- (1) No contextualizado. Riesgos genéricos de IT aplicados equally.
- (2) Mención de amenazas. Reconocemos ransomware + DDoS existen; análisis superficial.
- (3) Evaluación sector-específica. Amenazas financieras identificadas; prioridad diferenciada.
- (4) Evaluación amenazas + threat intelligence. Análisis based on ENISA/INCIBE data; threat feeds integradas.
- (5) Evaluación continua + threat intel + scenario planning. Ejercicios "red team" anuales; escenarios de worst-case; respuesta evoluciona.

Pregunta 2.1.5 ¿La organización emplea framework FAIR (Factor Analysis of Information Risk) o equivalente para cuantificación financiera de riesgos cibernéticos?

- (1) No. Riesgos se describen narrativamente ("grave", "crítico").
- (2) Iniciativa incipiente. Exploramos FAIR; no implementado aún.
- (3) FAIR piloto. Algunos riesgos cuantificados; no normalizado.
- (4) FAIR implementado. ALE (Annual Loss Expectancy) calculado para activos críticos; integrado en reporte riesgos.
- (5) FAIR + decisiones monetarias integradas. ALE guía presupuestación seguridad; inversión ROI-justified; finance + security alineados.

2.2 Tratamiento y Mitigación de Riesgos

Pregunta 2.2.1 ¿Existe plan formalizado de tratamiento/mitigación de riesgos identificados, con propietarios, timelines y presupuesto?

- (1) No existe plan. Identificamos riesgos; no sabemos qué hacer.
- (2) Respuestas ad-hoc. Mitigamos cuando recursos disponibles; no priorizado.
- (3) Plan documentado. Riesgos altos mitigados; medianos dependen de presupuesto.
- (4) Plan formal. Todos riesgos altos+medianos tienen mitigación roadmap; presupuesto asignado.
- (5) Plan integrado + monitoreo. Roadmap multi-año; presupuesto garantizado; seguimiento trimestral; ajustes conforme evolución.

Pregunta 2.2.2 ¿La estrategia de mitigación incluye inversión proporcional en seguridad (como % presupuesto TIC)?

- (1) <2% presupuesto TIC. Ciberseguridad = afterthought presupuestario.
- (2) 2-4%. Reconocemos su importancia; recursos limitados.
- (3) 5-8%. Presupuesto significativo; dedicado formalmente.
- (4) 9-15%. Inversión sustancial; alineada con risk profile.
- (5) 15%+. Inversión estratégica; distribuido: 35% controls avanzados, 20% testing, 15% terceros, 15% training, 15% respuesta.

Pregunta 2.2.3 ¿Se comunican riesgos TIC identificados + planes mitigación a Junta Directiva formalmente?

- (1) Nunca. Detalles técnicos no son "nivel ejecutivo".
- (2) A veces, informalmente. Conversaciones anecdóticas; no reportes.
- (3) Reportes ad-hoc. Si algo crítico; no cadencia regular.
- (4) Reportes trimestrales. Riesgos prioritarios + planes a Junta; escalation clara.
- (5) Reportes + dashboards + trainings. Trimestral governance meetings; real-time dashboards; board training anual; informed decision-making.

MÓDULO 3: GESTIÓN DE INCIDENTES TIC

3.1 Capacidad de Detección

Pregunta 3.1.1 ¿Se ha implementado SIEM (Security Information and Event Management) u equivalente para monitoreo centralizado?

- (1) No existe. Log files esparcidos en servidores; nobody reviews them.
- (2) Logging básico. Algunos eventos registrados; análisis manual ocasional.
- (3) Logging centralizado, análisis manual. ELK / Splunk / similar; reviews no automatizadas.
- (4) SIEM completo, alertas automatizadas. Rules implementadas; alertas escaladas; SOC staffed.
- (5) SIEM + ML + 24/7 SOC. Behavioral analytics; automated threat hunting; global SOC coverage.

Pregunta 3.1.2 ¿Cuál es el Mean Time To Detect (MTTD) promedio de incidentes de seguridad en su organización?

- (1) >24 horas. Descubrimos incidentes cuando "alguien se da cuenta".
- (2) 8-24 horas. Día siguiente típicamente.
- (3) 2-8 horas. Pocas horas; depende del tipo incidente.
- (4) 30-120 minutos. Detección dentro de 1-2 horas para la mayoría.
- (5) <15 minutos. DORA target alcanzado; alertas inmediatas para incidentes críticos.

Pregunta 3.1.3 ¿Se realiza monitoreo automático de logs, eventos de seguridad, y anomalías comportamentales?

- (1) No automatizado. Revisión manual cuando "pensamos en ello".
- (2) Automatización básica. Scripts cron para algunos eventos; ineficiente.
- (3) Automatización parcial. SIEM con reglas básicas; cobertura ~50% eventos relevantes.
- (4) Automatización extensiva. Reglas SIEM cobertura; baseline behavior establecida; alertas configuradas.
- (5) Automatización + ML. Behavioral analytics; anomaly detection; correlation avanzada; tuning continuo.

Pregunta 3.1.4 ¿Se realiza threat hunting proactivo (búsqueda manual de indicadores de compromiso)?

- (1) No. Threat hunting es lujo; reactivos es norma.
- (2) Iniciativas puntuales. Ocasionalmente buscamos "cosas raras".
- (3) Programa informal. Threat hunters designados pero sin cadencia fija.
- (4) Programa mensual. Hunting sessions programadas; hipótesis investigadas; reportes.
- (5) Programa continuo + Intel. Threat hunting semanal; integrado con threat intel feeds; técnicas MITRE ATT&CK comportamiento adversario replicado.

3.2 Clasificación de Incidentes

Pregunta 3.2.1 ¿Se han implementado criterios formales de clasificación de incidentes conforme DORA RTS (Artículos 2, 18)?

- (1) No definidos. "Mayor" o "menor" es toda la clasificación.
- (2) Criterios básicos. Algunos umbrales internos; no alineados DORA.
- (3) Criterios parcialmente alineados DORA. Algunos umbrales cuantitativos; otros cualitativos faltantes.
- (4) Criterios completos DORA. Umbrales numéricos (clientes, transacciones, impacto económico); evaluación servicios críticos; rubric de clasificación.
- (5) Criterios DORA + automatización de scoring. Tools de clasificación automática; thresholds integrados en SIEM; scoring proporcional.

Pregunta 3.2.2 ¿Se evalúan incidentes conforme criterios de materialidad DORA (p.ej., # clientes afectados, impacto económico €100K+)?

- (1) No se evalúan materialmente. Reportamos todos = ruido.
- (2) Evaluación informal. "Parece grave" es métrica.
- (3) Evaluación parcial. Algunos criterios (clientes) sí; otros (impacto económico) no.
- (4) Evaluación completa. Umbrales cuantitativos + cualitativos; documentado.
- (5) Evaluación + FAIR integration. Materialidad económica cuantificada via FAIR; decisiones classification evidence-based.

Pregunta 3.2.3 ¿Los criterios de clasificación incluyen evaluación de servicios críticos/importantes y propagación geográfica?

- (1) No. Tamaño incidente = solo métrica.
- (2) Parcial. Sabemos qué servicios son "críticos" internamente; no en clasificación formal.
- (3) Documentado, no automatizado. Rubric existe; evaluación manual.
- (4) Documentado + parcialmente automatizado. Servicios críticos mapeados; propagación considerada; scoring.
- (5) Totalmente integrado. Servicios críticos auto-identificados; propagación geográfica detectada; impact scoring multi-dimensional.

3.3 Proceso de Notificación de Incidentes

Pregunta 3.3.1 ¿Existen procedimientos formales de notificación de incidentes mayores a autoridades supervisoras conforme DORA (4h inicial, 72h intermedio, 30d final)?

- (1) No formalizados. Notificamos cuando recordamos.
- (2) Procedimiento escrito. Existe, pero no practicado regularmente.
- (3) Procedimiento definido, practicado ocasionalmente. Drills algunos; timelines a menudo incumplidas.
- (4) Procedimiento formalizado, practicado anualmente. Dry-runs; checklist; responsables designados.
- (5) Procedimiento + automatización + escalation clara. Workflows formales; alertas automáticas; escalation path; cumplimiento histórico 95%+.

Pregunta 3.3.2 ¿Se tienen identificados puntos de contacto de escalation para notificación a autoridades supervisoras?

- (1) No designados. "Alguien" lo hará probablemente.
- (2) Contactos identificados informalmente. Sabemos quién llamar; no documentado.
- (3) Contactos documentados, equipo asignado. CISO/CRO designados; lista de autoridades compilada.
- (4) Equipo + procedimiento. Roles definidos (CISO, legal, compliance); escalation rules; templates notificación.
- (5) Equipo + automatización + comunicación integrada. Workflows ticket; notificación automática a autoridades vía portales; registro audit; coordinación con aseguradoras.

Pregunta 3.3.3 ¿Se mantiene Log Detallado de Incidentes (timestamps, descripción, acciones, comunicaciones)?

- (1) No. Incidentes ocurren; info se pierde.
- (2) Ad-hoc. Algunos logs; inconsistentes; gaps.
- (3) Logs documentados. Tickets en sistema; info variable de completo.
- (4) Logs completos, estructurados. Template incident reporting; todos detalles capturados; retroactivamente auditable.
- (5) Logs + analytics + forensics. Logs inmutables; metadatos completos; correlación automática; forensics capability integrada.

3.4 Respuesta y Remediación

Pregunta 3.4.1 ¿Existe plan formalizado de Respuesta a Incidentes (Incident Response Plan) documentado y practicado?

- (1) No existe plan. Improvisamos cada vez.
- (2) Plan esquelético. Existe borradores; desactualizado.
- (3) Plan documentado. Roles, responsabilidades, steps definidos; practicado ocasionalmente.
- (4) Plan formalizado + drills anuales. Pruebas tabletop; roles practicados; comunicación probada.
- (5) Plan integral + drills trimestrales + evolución continua. Playbooks por tipo incidente; comunicación probada; lessons learned integradas; respuesta mejorada continuamente.

Pregunta 3.4.2 ¿Cuál es el Mean Time To Restore (MTTR) promedio para incidentes críticos?

- (1) >24 horas. Remediación lenta; impacto extendido.
- (2) 8-24 horas. Medio día mínimo típicamente.
- (3) 2-8 horas. Pocas horas para la mayoría críticos.
- (4) 30-120 minutos. Restauración rápida; SLA cumplida.
- (5) <30 minutos para servicios críticos. RTO DORA target alcanzado; automatización + preparación.

Pregunta 3.4.3 ¿Se documentan y comunican "lecciones aprendidas" post-incidente para prevenir recurrencia?

- (1) No. Incidente terminado = closed; sin aprendizaje.
- (2) Informal. Team talks "qué pasó"; nada documentado.
- (3) Documentación ad-hoc. A veces se redacta post-mortem; inconsistente.
- (4) Proceso formalizado. Post-mortems dentro 72h; accionables identificadas; seguimiento trimestral.
- (5) Integrado en mejora continua. Post-mortems blameless; accionables con SLAs remediación; cambios validados; trending analysis; cultura mejora.

MÓDULO 4: ANÁLISIS DE VULNERABILIDADES

4.1 Gestión de Vulnerabilidades - Evaluación

Pregunta 4.1.1 ¿Se realizan evaluaciones de vulnerabilidades automatizadas (scanning) regularmente conforme Artículo 24 DORA?

- (1) No se realiza scanning. Sin idea de vulnerabilidades = sin sorpresas (falso).
- (2) Scanning ocasional. 1-2x por año; resultados no sistematizados.
- (3) Scanning mensual. Automated scans ejecutados; algunos sistemas no cubiertos.
- (4) Scanning semanal. Cobertura ~90% sistemas; CVSS scoring automatizado.
- (5) Scanning continuo. Real-time discovery; configuración dinámica; baseline de vulnerabilidades mantenido.

Pregunta 4.1.2 ¿Se utiliza CVSS (Common Vulnerability Scoring System) para clasificación de severidad?

- (1) No. Severidades determinadas by gut feeling.
- (2) CVSS mencionado. Concepto conocido; no aplicado sistemáticamente.
- (3) CVSS implementado parcialmente. Scoring base aplicado; métricas temporal/ambiental no.
- (4) CVSS implementado. Base + temporal scoring; umbrales de crítico/alto/medio/bajo definidos.
- (5) CVSS + EPSS integration. CVSS severidad + EPSS explotabilidad; risk-based prioritization; decisiones remediation data-driven.

Pregunta 4.1.3 ¿Se emplea EPSS (Exploit Prediction Scoring System) para estimar probabilidad real de explotación?

- (1) No conocido. EPSS = ¿Qué es eso?
- (2) Concepto conocido. Aware; no implementado aún.
- (3) Piloto. EPSS scores consultados para algunos sistemas.
- (4) Implementado. EPSS feed integrado; scores actualizados diariamente; considerado en priorización.
- (5) Integrado en decisiones. EPSS + CVSS; máquinas de scoring; alto EPSS + CVSS ≥ 7.0 = remediación <7 días.

Pregunta 4.1.4 ¿Se mantiene inventario priorizado de vulnerabilidades con estado de remediación?

- (1) No. Scanning results olvidados rápidamente.
- (2) Ad-hoc. Algunas vulnerabilidades tracked; data en emails/spreadsheets.
- (3) Inventario parcial. Tracked en herramienta; no todas vulnerabilidades; priorización manual.
- (4) Inventario completo. Todas vulnerabilidades críticas/altas tracked; status actualizado; priorización CVSS/EPSS.
- (5) Inventario dinámico + trending. Real-time tracking; análisis tendencias; dashboard governance; SLA remediation per criticidad.

4.2 Pruebas de Penetración

Pregunta 4.2.1 ¿Se realizan pruebas de penetración anuales (Penetration Testing / Penetration Assessment)?

- (1) Nunca realizadas. Red team = concepto lejano.
- (2) Realizadas ocasionalmente. <1 vez cada 2 años.
- (3) Anuales realizadas. 1 pentest/año; cobertura parcial sistemas.
- (4) Anuales + seguimiento. 1+ pentests/año; cobertura ~80% funciones críticas; resultados remediados.
- (5) Anuales + TLPT bienal. Pentest anual + TLPT (red team real) cada 3 años para significativas; cobertura 90%+ críticos; lessons learned integradas.

Pregunta 4.2.2 ¿Se ha implementado Threat-Led Penetration Testing (TLPT) conforme TIBER-EU / DORA RTS?

- (1) No conocido. TLPT = ¿Qué es?
- (2) Concepto conocido. Aware; no presupuestado.
- (3) Planificación iniciada. Scope siendo definido; timing TBD.
- (4) TLPT planificado. RFP enviado; testers identificados; ejecución 2026.
- (5) TLPT completado. Ejercicio red team realizado; blue team + red team interacción documentada; hallazgos remediados; mejoras implementadas.

Pregunta 4.2.3 ¿Los pentest / TLPT incluyen evaluación de medidas técnicas (vulnerabilidades explotables)?

- (1) No. Pentests son teóricos / network scans.
- (2) Mínimamente. Algunos TTPs probados; cobertura limitada.
- (3) Parcialmente. External + internal network testing; limited application.
- (4) Comprehensivamente. External + internal + application + physical; multiple TTPs.
- (5) Exhaustivamente + supply chain. Multi-faceted; includes vendor compromise scenarios; third-party lateral movement tested; red team libre elegir tactics.

Pregunta 4.2.4 ¿Se han establecido KPIs para evaluar efectividad de testing (MTTD, vulnerabilities exploited, control gaps)?

- (1) No KPIs. Testing = "did we find stuff?" es métrica.
- (2) KPIs ad-hoc. Informalmente tracked; no dashboard.
- (3) KPIs documentados. MTTD + vulnerabilidades; reportados anualmente.
- (4) KPIs formalizados. Mean Time To Detect, Mean Time To Respond, Control Gap Rate; reportes trimestrales.
- (5) KPIs avanzados. Red Team KPIs (MTTIA, MTTR, TTP coverage); Purple Team interacción medida; trending; comparativos vs. industry.

MÓDULO 5: GESTIÓN DE TERCEROS

5.1 Evaluación de Riesgos de Terceros

Pregunta 5.1.1 ¿Se mantiene inventario completo de proveedores TIC con clasificación de criticidad?

- (1) No existe inventario. "Usamos servicios de cloud"; lista incompleta.
- (2) Inventario incompleto. Algunos proveedores documentados; muchos gaps.
- (3) Inventario documentado. Mayoría proveedores listados; criticidad informal.
- (4) Inventario completo + criticidad formalizada. Todas terceras listadas; tiering documentado (crítica/importante/normal).
- (5) Inventario dinámico + relaciones mapeadas. Real-time updates; sub-contratistas incluidas; mapping dependencias; SBOM-style clarity.

Pregunta 5.1.2 ¿Se realiza due diligence inicial (evaluación de riesgos) de proveedores críticos conforme Artículos 28-29 DORA?

- (1) Nunca. Confiamos en reputación.
- (2) Ad-hoc. Algunos proveedores evaluados; inconsistente.
- (3) Parcialmente. Evaluación de seguridad básica; financiera no siempre.
- (4) Formal para críticos. Questionnaire DORA; reference checks; ISO/SOC2 verificación.
- (5) Comprehensive + tiered. Due diligence proporcional a criticidad; FAIR risk scoring; site visits; third-party audits.

Pregunta 5.1.3 ¿Se evalúa solidez financiera de proveedores críticos para entender riesgo continuidad?

- (1) No evaluada. No sabemos si irán a quiebra.
- (2) Informalmente. Leak en news; no due diligence formal.
- (3) Evaluación financiera básica. Credit rating consultado; Dun & Bradstreet check.
- (4) Evaluación formal. Financial statements revisados; credit ratings; trend analysis.
- (5) Monitoreo continuo. Real-time financial health monitoring; credit feed integrada; alerts para degradaciones; alternative vendor readiness.

Pregunta 5.1.4 ¿Se verifica postura cibernética de proveedores (certificaciones ISO 27001, SOC2, TIBER-EU, etc.)?

- (1) No verificada. Asumimos estándar.
- (2) Informalmente. Preguntamos "¿tienes seguridad buena?"
- (3) Verificación documental. Certificaciones solicitadas; validez spot-check.
- (4) Verificación formal. ISO 27001 / SOC2 Type II requerido; evidencia audit revisada; gap analysis.
- (5) Evaluación proporcional + auditoria. Cybersecurity assessment proporcional a criticidad; on-site audits para los críticos; third-party testers; continuous monitoring.

5.2 Gestión Contractual

Pregunta 5.2.1 ¿Los contratos incluyen cláusulas explícitas de seguridad TIC conforme Artículo 30 DORA?

- (1) No. Contratos son estándar vendor; seguridad no mencionada.
- (2) Mención genérica. "Data protection" línea vaga.
- (3) Cláusulas básicas. NDA + data security; RTO/RPO no definidos.
- (4) Cláusulas DORA. Incident reporting SLAs (24h, 72h, 30d); audit rights; sub-contractor clauses; notification requirements.
- (5) Cláusulas exhaustivas. DORA + FAIR-based SLAs; salida provisions (90-day wind-down); business continuity; crisis communication; governance escalation; aseguradora requirements.

Pregunta 5.2.2 ¿Se han definido Acuerdos de Nivel de Servicio (SLA) explícitos con RTO (Recovery Time Objective) y RPO (Recovery Point Objective)?

- (1) No definidos. "Standard cloud SLAs" es respuesta típica.
- (2) SLAs genéricos. 99.9% uptime; sin detalles RTO/RPO.
- (3) SLAs documentados. RTO/RPO definidos para servicios; validación no regular.
- (4) SLAs formales. Críticos < 4h RTO; RPO < 1h; periodically tested.
- (5) SLAs + testing. RTO/RPO DORA-aligned; quarterly failover tests; penalties/termination clauses; continuous monitoring compliance.

Pregunta 5.2.3 ¿Los contratos incluyen derechos explícitos de auditoría y acceso a reportes de seguridad del proveedor?

- (1) No. No tenemos derecho de auditar.
- (2) Mencionado vagamente. "Podemos auditar si queremos" tipo indefinido.
- (3) Derecho documentado. Auditoría permitida; frecuencia no especificada.
- (4) Derecho formalizado. Auditoría annual minimum; security reports trimestral; right-of-inspection data center.
- (5) Derecho + ejercicio regular. Auditoría contractual ejercida; on-site inspections; third-party assurance (SOC2); datos acceso management.

Pregunta 5.2.4 ¿Existe plan de salida (exit clause) documentado para transición en caso de terminación de contrato?

- (1) No existe plan. "Nos quedaremos con ellos para siempre" (famous last words).
- (2) Plan informal. Vaguely discussed; not documented.
- (3) Plan documentado. Exit provision existe; detalles incompletos.
- (4) Plan formal. 90-day wind-down; data return procedure; continuity support; documented.
- (5) Plan + ejercicio regulares. Plan formal; contract-specified; exercised annually (tabletop); vendor cooperation verified; alternative vendors on standby.

5.3 Monitoreo Continuo

Pregunta 5.3.1 ¿Se realiza monitoreo continuo post-contratual de riesgos de terceros conforme Artículo 30 DORA?

- (1) No monitoreado. After signing, nos olvidamos.
- (2) Monitoreo ad-hoc. Si hay problema, investigamos.
- (3) Monitoreo anual. Reassessment yearly; revisión de incidentes.
- (4) Monitoreo semestral. Quarterly reviews; incidentes tracked; alertas para degradaciones.
- (5) Monitoreo continuo. Real-time feeds (threat intel, credit, news); automated alerts; monthly governance review; dynamic risk scoring.

Pregunta 5.3.2 ¿Se integra threat intelligence (breach data, vulnerabilities) para monitorear compromisos de proveedores?

- (1) No integrado. No sabemos si han sufrido breach.
- (2) Informalmente. Leemos news; sin sistema.
- (3) Monitoreo básico. Breach databases consultadas ocasionalmente; manual.
- (4) Monitoreo regular. Dark web monitoring; breach feeds; vendor name searched monthly.
- (5) Monitoreo automatizado. Continuous threat intel feeds; alerts for mentioned vendors; compromised credential feeds; supply chain attack scenarios evaluated.

Pregunta 5.3.3 ¿Se han establecido KPIs para monitorear compliance de terceros con SLAs y requisitos DORA?

- (1) No KPIs. Compliance es tema vago.
- (2) KPIs informales. Tracked in spreadsheets; not formalized.
- (3) KPIs documentados. SLA compliance %, incident reporting adherence; periodic reporting.
- (4) KPIs formales. Uptimes measured; SLA breaches escalated; compliance score calculated.
- (5) KPIs + dashboard. Real-time compliance dashboard; risk score integrated; automated escalation; governance reports; contract penalties triggered automatically.

MÓDULO 6: SEGURIDAD EN LA INFORMACIÓN (IAM, Acceso, Criptografía)

6.1 Identity and Access Management (IAM)

Pregunta 6.1.1 ¿Se ha implementado sistema de gestión de identidades y acceso (IAM / Identity Management)?

- (1) No existe sistema centralizado. Acceso local a cada aplicación; duplicación cuentas.
- (2) Sistema básico. LDAP o AD; no MFA.
- (3) Implementado. AD/LDAP centralizado; MFA para algunos usuarios críticos.
- (4) Sistema completo. AD/LDAP + MFA universal (~80%); roles RBAC documentados; audit trails.
- (5) IAM avanzado. Privileged Access Management (PAM); SSO; MFA universal; Zero Trust principles aplicados; behavioral analytics.

Pregunta 6.1.2 ¿Se ha implementado Multi-Factor Authentication (MFA) en acceso a sistemas críticos?

- (1) No. Passwords only; MFA concept known but not deployed.
- (2) MFA piloto. Admin accounts solamente; resto not required.
- (3) MFA parcial. ~50% critical accounts; inconsistent.
- (4) MFA generalizado. 85%+ usuarios críticos; aplicaciones críticas; remoto = mandatorio.
- (5) MFA universal + strong. 100% MFA requerido; hardware keys para privilegiados; phishing-resistant authentication.

Pregunta 6.1.3 ¿Se revisan periódicamente permisos de acceso (Privileged Access Review) para eliminar acceso innecesario?

- (1) Nunca revisamos. Una vez creada, cuenta vive para siempre.
- (2) Revisiones ad-hoc. Ocasionalmente; inconsistente.
- (3) Revisiones anuales. Formal review; completitud ~60%.
- (4) Revisiones semestrales. Documentadas; completitud ~90%; derechos remediated.
- (5) Revisiones continuas + automatizadas. Quarterly compliance reviews; automated privilege analysis; entitlements revoked same-day; segregation of duties monitored.

Pregunta 6.1.4 ¿Se gestiona acceso privilegiado (Privileged Access Management / PAM)?

- (1) No formalizado. Admin passwords compartidas; vault no existe.
- (2) Vault básico. Password manager existe; políticas de rotación débiles.
- (3) Vault implementado. Rotación automática parcial; audit logging.
- (4) PAM completo. Vault con MFA; rotación automática; session recording; alert en acceso privilegiado.
- (5) PAM + Zero Trust. Just-In-Time access; approval workflows; session monitoring; decentralized trust; anomaly detection.

6.2 Criptografía y Protección de Datos

Pregunta 6.2.1 ¿Se cifran datos en tránsito (TLS/SSL) y en reposo conforme estándares modernos?

- (1) No. Datos en texto plano; encriptación no implementada.
- (2) Parcialmente. HTTPS para web; datos internos en texto.
- (3) Mayormente. TLS 1.2+ requerido; almacenamiento cifrado para sensibles.
- (4) Completo. TLS 1.3 para todo tránsito; AES-256 para datos sensibles; key management básico.
- (5) Avanzado. TLS 1.3 universal; AES-256+ todo datos; HSM para keys; rotación automática; quantum-safe crypto roadmap.

Pregunta 6.2.2 ¿Existe gestión formal de claves criptográficas (Key Management)?

- (1) No. Keys en código, configuraciones, o compartidas.
- (2) Básica. Keys almacenadas; rotación manual ocasional.
- (3) Parcialmente formalizada. KMS exists; rotación policy; auditing basic.
- (4) Formalizada. KMS completo; rotación automática; audit comprehensive; separation of duties.
- (5) Avanzada. Externalized KMS (AWS KMS, Azure Key Vault); key lifecycle automatizado; FIPS 140-2 Level 3; disaster recovery testeado.

Pregunta 6.2.3 ¿Se ha implementado Data Loss Prevention (DLP) para prevenir exfiltración de datos sensibles?

- (1) No existe. Data puede fluir sin restricción.
- (2) Básico. Algunos controles endpoint; coverage limitada.
- (3) Implementado parcialmente. DLP email + endpoint; policies ~ 50% cobertura.
- (4) Implementado. DLP email, endpoint, network; políticas documentadas; alerting enabled.
- (5) Avanzado. DLP + behavioral analytics; cloud-aware DLP; incident response automatizado; false positive tuning.

MÓDULO 7: PRUEBAS DE RESILIENCIA OPERATIVA

7.1 Continuidad de Negocio y Recuperación ante Desastres

Pregunta 7.1.1 ¿Se han identificado y documentado funciones críticas con RTO/RPO definidos?

- (1) No documentado. Todos servicios son "críticos" por igual.
- (2) Parcialmente. Algunas funciones identificadas; RTO/RPO vago.
- (3) Documentado. Funciones críticas mapeadas; RTO/RPO preliminar.
- (4) Formalizado. Todas críticas/importantes identificadas; RTO/RPO específico por función.
- (5) Formalizado + validado. Documentado; tested en DR exercises; evoluciona conforme business changes; Junta aware.

Pregunta 7.1.2 ¿Existe Plan de Continuidad de Negocio (Business Continuity Plan / BCP) documentado?

- (1) No existe. ¿Qué es BCP?
- (2) Existe esquema. Draft documentado; desactualizado probablemente.
- (3) Plan formalizado. Documentado; actores identificados; procedimientos básicos.
- (4) Plan completo. Todos funcionarios involucrados; procedures detalladas; contact lists; backup sites definidos.
- (5) Plan integrado + testeado. Formalizado; annual tabletop exercises; quarterly site activations; lessons learned incorporated; insurance coordinated.

Pregunta 7.1.3 ¿Se realizan ejercicios de Continuidad (tabletop, dry-run, full activation) regularmente?

- (1) Nunca. Plans exist; nobody practices.
- (2) Ad-hoc. Ocasionalmente; inconsistente.
- (3) Anualmente. Tabletop exercise anual; results documented.
- (4) Semestrales. Tabletop semi-annual; dry-run site activation anual; deficiencias remediated.
- (5) Continuos + multi-escenarios. Quarterly tabletop; semi-annual site activation; yearly full activation; multi-scenario testing; vendor recovery tested.

Pregunta 7.1.4 ¿Se mantiene Disaster Recovery (DR) site con sincronización de datos?

- (1) No existe DR site. Recuperación es esperanza.
- (2) DR site básico. Existe; datos manuales, actualizaciones inconsistentes.
- (3) DR site formalizado. Sync automático parcial; RTO ~8-24h.
- (4) DR site completo. Replicación en tiempo-real; RTO <4h; RPO <1h; testado anualmente.
- (5) DR + geografía redundante. Múltiples sites; geo-distributed; RPO cercano-zero; RTO minutos críticos; automatización failover; cloud-native DR.

7.2 Evaluación de Vulnerabilidades (Testing Schedule)

Pregunta 7.2.1 ¿Se ha establecido programa formalizado de testing de vulnerabilidades con cadencia documentada?

- (1) No formalizado. Testing cuando recordamos.
- (2) Programa básico. Anual scanning planificado; inconsistencia.
- (3) Programa documentado. Cadencia anual: scanning vulnerabilities + penetration testing; publicado.
- (4) Programa formalizado. Trimestral scanning; anual penetration; bienal TLPT para significativas; reportes programados.
- (5) Programa integrado. Continua scanning; monthly analysis; anual pentesting; bienal TLPT; threat intel + testing integrated; roadmap multi-año.

Pregunta 7.2.2 ¿Se realizan simulaciones de escenarios de adversarios (cyber escenarios / wargames)?

- (1) No realizadas. Scenarios son concepto abstracto.
- (2) Informalmente. Conversaciones "qué pasaría si"; no documentado.
- (3) Exercises documentados. Tabletop scenarios anuales; documentados.
- (4) Simulaciones regulares. Quarterly cyber scenarios; roles assigned; outcomes documented; metrics captured.
- (5) Simulaciones avanzadas. Monthly scenarios; MITRE ATT&CK aligned; red/blue participation; automated scoring; improvements tracked over time.

Pregunta 7.2.3 ¿Se han definido target metrics para resilience (MTTD, MTTR, Recovery Rate)?

- (1) No definidos. Resilience es concepto fuzzy.
- (2) Informalmente mencionados. "Deberíamos ser rápidos"; sin numbers.
- (3) Metrics preliminares. Propuestos; no implementados.
- (4) Metrics formalizados. MTTR <30min; MTTR <4h críticos; Recovery Rate >95%; reportados.
- (5) Metrics + tendencias. KPIs formalizados; tracked monthly; comparativos históricos; industry benchmarks; governance dashboard.

MÓDULO 8: CAPACITACIÓN Y CONCIENCIA EN SEGURIDAD

8.1 Programa de Capacitación

Pregunta 8.1.1 ¿Se ha implementado programa formal de capacitación en seguridad para empleados?

- (1) No existe. Seguridad es responsabilidad de IT.
- (2) Capacitación ad-hoc. Ocasionalmente emails; sin curriculum.
- (3) Programa básico. Training anual requerido; contenido genérico.
- (4) Programa formalizado. Training obligatorio anual; contenido rol-specific; tracking compliance.
- (5) Programa comprehensivo. Onboarding mandatory; annual + role-specific training; phishing simulations; incident reporting procedures; board training; evolution based on incidents.

Pregunta 8.1.2 ¿La capacitación incluye tópicos DORA/GRC específicos (gestión riesgos TIC, reporting incidentes, terceros)?

- (1) No. Training = "no hagas click en emails raros".
- (2) Mencionado genéricamente. "Ciberseguridad" slide deck.
- (3) Parcialmente incluido. Algunos tópicos GRC; cobertura ~40%.
- (4) Incluido formalmente. DORA pilares cubiertos; incident reporting procedures; third-party awareness.
- (5) Integrado comprehensivamente. DORA requirements explicados; role-specific requirements; executive training on governance; vendor risk awareness.

Pregunta 8.1.3 ¿Se realizan simulaciones de phishing para evaluar vulnerabilidad de empleados?

- (1) Nunca realizadas. Phishing sería "unfair" (realidad: es fair).
- (2) Informales. A veces enviamos phishing test; sin seguimiento.
- (3) Programa anual. Phishing campaigns; click rates tracked.
- (4) Programa semestral. Quarterly phishing simulations; click rate <10% target; remedial training triggered.
- (5) Programa continuo + avanzado. Monthly simulations; personalized training for clickers; advanced tactics (vishing, whaling); reporting metrics; behavioral change measured.

Pregunta 8.1.4 ¿Existe tasa de cumplimiento medida para completación de training de seguridad?

- (1) No medido. Suponemos todos completan.
- (2) Informalmente. Alguien mira números ocasionalmente.
- (3) Reportado anualmente. Completion % calculado; documentado.
- (4) Medido quarterly. Compliance rate por departamento; gaps identificados; reminders automatizadas.
- (5) Medido + incentivos. Monthly tracking; departmental accountability; non-compliance escalated; incentives para 100% completion.

8.2 Cultura de Seguridad

Pregunta 8.2.1 ¿Se promueve una cultura donde empleados reportan preocupaciones de seguridad sin miedo a represalias?

- (1) No. Reportar problema = "eres problema".
- (2) Parcialmente. Policy exists; implementación inconsistente.
- (3) Parcialmente implementado. Algunos reportes; confianza limitada.
- (4) Implementado. Anonymous reporting channels; no-reprisal policy; examples de acting on reports.
- (5) Embebido en cultura. Blameless culture; incentives para reporting; visible action on reports; leadership modeling; metrics de reported incidents.

Pregunta 8.2.2 ¿Se reconocen y comunican ejemplos de comportamiento seguro positivo?

- (1) Nunca. Seguridad = obligación, no logro.
- (2) Ocasionalmente. Informal; peer recognition.
- (3) Reportado formalmente. Security wins comunicados; departamental.
- (4) Programa de reconocimiento. Reportes mensuales; ejemplos destacados; incentivos.
- (5) Programa integral. Monthly recognition programa; incentives; leaderboards; gamification; leader modeling.

Pregunta 8.2.3 ¿La gobernanza y leadership comunicaban regularmente importancia de seguridad?

- (1) Raramente. "Otro memo de IT".
- (2) Ocasionalmente. CEO menciona; inconsistente.
- (3) Regularmente. Mensajes trimestrales; newsletters.
- (4) Formalmente integrado. Leadership messages; security town halls; all-hands updates.
- (5) Integrated en governance. C-suite comunicación mensual; all-hands quarterly; security as strategic priority; budget/resources reflect commitment.

MÓDULO 9: CUMPLIMIENTO REGULATORIO Y AUDITORÍA

9.1 Mapeo de Requisitos DORA

Pregunta 9.1.1 ¿Se ha realizado mapeo exhaustivo de los requisitos DORA vs. estado actual de implementación (GAP Analysis)?

- (1) No realizado. No sabemos qué requiere DORA exactamente.
- (2) Mapeo preliminar. Borrador realizado; incompleto.
- (3) Mapeo documentado. Todos pilares DORA vs. estado; cobertura ~70%.
- (4) Mapeo completo. 130+ requisitos mapeados; GAP scoring formalizado.
- (5) Mapeo + tracking. Exhaustivo mapeo; remediación roadmap; quarterly progress; governance escalation; external audit aligned.

Pregunta 9.1.2 ¿Se mantiene registro de información DORA (Registro de Información) conforme Artículo 6(5)?

- (1) No existe. Concepto no conocido.
- (2) Iniciativa incipiente. Comenzamos a documentar; desorganizado.
- (3) Parcialmente documentado. Algunas categorías; gaps significativos.
- (4) Documentado formalmente. Todas categorías DORA covered; actualizado semestralmente.
- (5) Digitalizado + automatizado. Registry dinamizado; integrado en governance systems; auto-updated conforme cambios; auditable.

Pregunta 9.1.3 ¿Se ha realizado autoevaluación CNMV/DORA conforme directrices supervisoras?

- (1) No realizada. Esperamos la auditoría supervisora.
- (2) Iniciativa incipiente. Comenzamos; no completada.
- (3) Autoevaluación parcial. Completada; resultados no documentados.
- (4) Autoevaluación formal. Completada conforme CNMV guidance; resultados documentados; remediación en curso.
- (5) Autoevaluación + tercero validación. Completada; external auditor review; roadmap DORA formalizado; supervisora awareness.

9.2 Proceso de Auditoría y Assurance

Pregunta 9.2.1 ¿Se realiza auditoría interna anual de cumplimiento de políticas de seguridad TIC?

- (1) No. Auditoría interna no toca seguridad.
- (2) Ad-hoc. Ocasionalmente si hay incidente.
- (3) Auditoría anual. Scope limitado; cobertura ~50%.
- (4) Auditoría formal anual. Todos pilares evaluados; hallazgos documentados; remediación planeada.
- (5) Auditoría + continuous monitoring. Auditoría formal + quarterly spot-checks; continuous control testing; issues escalated immediately.

Pregunta 9.2.2 ¿Se realiza auditoría externa de seguridad (por auditor independiente) regularmente?

- (1) Nunca. Auditoría externa = gasto.
- (2) Ad-hoc. Si supervisor lo requiere.
- (3) Ocasional (cada 2-3 años). Cuando presupuesto permite.
- (4) Anual. External auditor contratado; DORA compliance evaluado; reporte formal.
- (5) Anual + continuous assurance. External audit annual; SOC2 Type II certification; continuous monitoring firma; third-party assurance integrada.

Pregunta 9.2.3 ¿Se documenta y comunica hallazgos de auditoría interna/externa a Junta Directiva?

- (1) Nunca. Hallazgos quedan en reporte técnico.
- (2) A veces. Si es severo; comunicación ad-hoc.
- (3) Reportado formalmente. Summary ejecutivo; presentado anualmente.
- (4) Formalizado. Hallazgos significativos / críticos a Junta trimestralmente; remediación tracked.
- (5) Integrado en governance. Todos hallazgos mapeados a riesgo; priorización formal; governance oversees remediación; status updates mensuales.

RESUMEN MÉTRICO Y SCORING

Cada módulo debe ser respondido completamente. Las respuestas generan un **Índice de Madurez de Ciberseguridad (CMI)** entre 1.0 (inicial/ad-hoc) y 5.0 (optimizado):

$$\text{CMI} = (\sum \text{puntuaciones respuestas} / \text{N preguntas total}) \times 5$$

Interpretación:

- **1.0-1.9:** Ad-hoc; riesgo crítico; immediate action required
- **2.0-2.9:** Developing; gaps significativos; roadmap urgente
- **3.0-3.9:** Managed; compliance baseline; mejora continua
- **4.0-4.9:** Integrated; best practices; madurez avanzada
- **5.0:** Optimized; continuous improvement; resilience sobresaliente

Módulos (ponderación sugerida):

- Gobernanza (15%): establece prioridad institucional
- Gestión Riesgos (20%): foundation técnica
- Gestión Incidentes (20%): respuesta operacional
- Vulnerabilidades (15%): postura técnica defensiva
- Terceros (15%): riesgo externo
- Capacitación (10%): factor humano
- Compliance (5%): regulatory alignment

$$\text{CMI Ponderado} = \sum (\text{CMI_módulo} \times \text{ponderación})$$

NOTAS ADICIONALES

Escala de Respuesta Guía

Para Preguntas Binarias ("¿Existe X?"):

- (1) No, no existe
- (2) Existe, pero muy incompleto/desactualizado
- (3) Existe, parcialmente completo
- (4) Existe, formalmente documentado
- (5) Existe, formalizado + integrado + evolucionando

Tonalidad Deliberada

La encuesta adopta lenguaje irónico pero propositivo:

- "Spoiler:" y "famous last words" añaden humor
- Pero cada opción es técnicamente rigurosa
- El humor facilita conversaciones honestas con stakeholders
- Evita sonar amenazante o acusatorio

Tiempo de Respuesta

Encuesta completa: 45-60 minutos para panel informado

- Requiere participación multi-función (CISO, compliance, operaciones, board)
- Best practice: sesión colaborativa (no respuestas individuales)